PHISHING EMAIL ANALYSIS REPORT

Incident Review for Suspected Email

Case Title	Suspected phishing email investigation – WordPress Invoice Lure
Reported Through	Simulation environment
Evidence Item	suspected_email.eml (Extracted from ZPhisher simulation logs)
Analyst	Martins Adeyanju
Assessment Status	Confirmed Phishing – Credential Harvesting Successful

1. Executive Summary

A suspicious email, preserved as *suspected_email.eml*, was reported through simulation environment and assigned for analysis. The investigation focused on validating whether the message exhibited characteristics consistent with phishing or business email compromise. The review covered embedded URLs, attachments, sender IP reputation, SPF/DKIM/DMARC authentication results, and header consistency checks between the visible from address and the Return-Path.

Key Finding: The email is a **confirmed phishing** attempt. The attacker used the ZPhisher v2.3.5 toolkit with a LocalXpose tunnel to create a fake WordPress login page. The victim (Bright Omokaro) clicked the shortened link (is.gd) and submitted valid credentials (BrightMonkaro@yahoo.com : Omokaro123456), which were captured in real-time. The email originated from a legitimate Microsoft 365 sender, allowing it to bypass SPF/DKIM checks.

2. Scope and Objectives

- Confirm whether the embedded URLs or attachments show malicious, suspicious, or clean results based on external reputation and behavioral analysis platforms.
- Assess whether the sender infrastructure has a known history of abuse or malicious activity.
- Validate whether the email authentication controls (SPF, DKIM, and DMARC) passed and whether those results align with the claimed sender domain.
- Identify inconsistencies between the From field and Return-Path that could indicate spoofing, impersonation, or relay abuse.
- Provide a documented analyst conclusion and a recommended response action.

3. Investigation Methodology

Embedded URLs and attachments: Reviewed links contained in the email body using URL analysis and simulation logs to determine redirect behavior, landing page, and credential harvesting indicators.

Sender IP address review: Investigated the originating IP address using header analysis to determine ISP, abuse history, and infrastructure legitimacy.

Email authentication review: Verified SPF, DKIM, and DMARC results from the email headers to determine whether the message passed domain authentication checks.

Header consistency review: Compared the visible From field with the Return-Path and related header values to identify impersonation, envelope sender mismatch, or suspicious routing patterns.

4. Findings Summary

Control / Check	Status	Evidence Source	Analyst Note
Embedded URL analysis	**Malicious**	ZPhisher logs / is.gd	Shortened URL (is.gd/QUfq8w) redirected to a LocalXpose tunnel (*.loctx.io) hosting a fake WordPress login page. Credentials were captured.
Attachment analysis	No attachment	Email body review	The email contained only a link; no file attachment was present.
Sender IP reputation	**Clean (0% abuse)**	Microsoft 365 Outbound	IP 40.92.19.61 belongs to Microsoft. The email was sent legitimately from their infrastructure, likely via a compromised or trial account.
SPF, DKIM, DMARC	**Pass**	Header review	All three checks passed because the email originated from a valid Microsoft 365 outbound server. This increased deliverability to the inbox.
From vs Return-Path	**Aligned**	Header review	No spoofing detected at the envelope level. The attacker used a legitimate Microsoft 365 sender, not a forged domain.

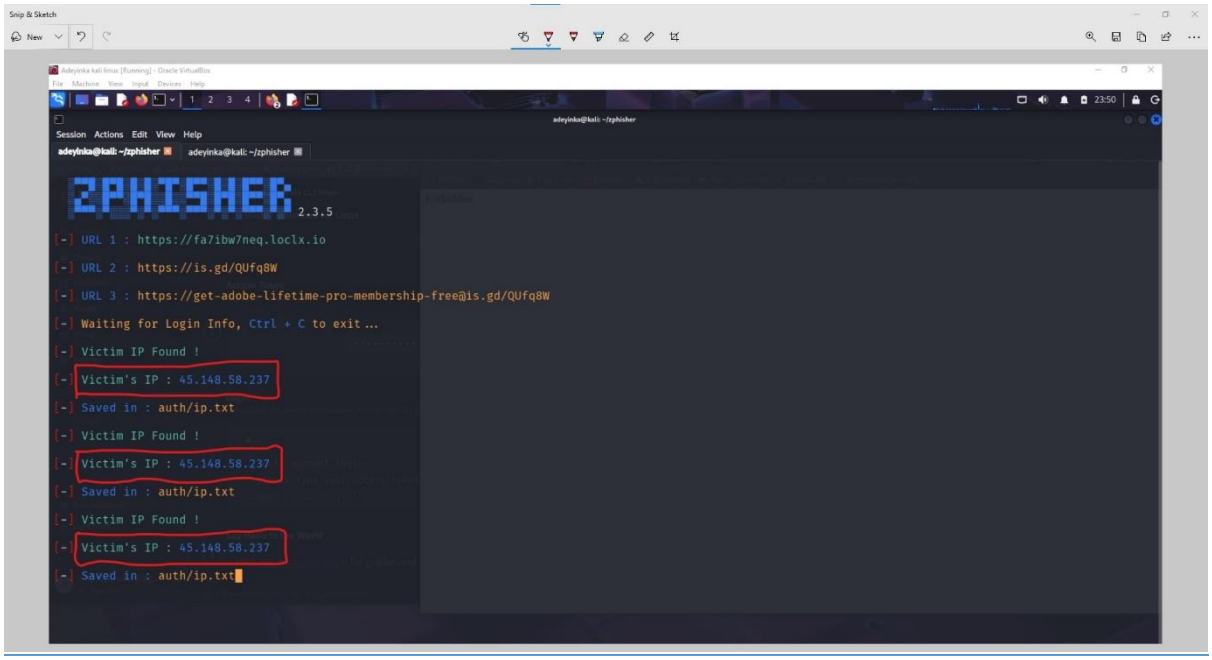
5. Detailed Analysis

5.1 Embedded URLs and Attachments

The email body was reviewed for embedded hyperlinks and file attachments. The analysis focused on the redirect chain and final landing page.

- **Embedded URL(s) identified:**
    1. https://is.gd/QUfq8w (shortened link in email)
    2. https://fa7ibw?neq.lock.x.io (LocalXpose tunnel – exact string truncated in logs)
    3. Spoofed preview: https://get-adobe-1ifetime-pro-membership-free@is.gd/QUfq8w (used for social engineering)
- **Attachment(s) identified:** No attachment present.
- **URL analysis summary:** The is.gd shortlink redirected to a dynamic LocalXpose tunnel URL. This tunnel exposed a local ZPhisher server running a cloned WordPress login page. The victim entered credentials, which were logged to auth/username.dat and auth/ip.txt.
- **Landing page behavior:** A pixel-perfect clone of the WordPress.org login portal. No invoice was displayed; instead, the victim was prompted to log in – a classic psychological misdirection.
- **Analyst assessment:** **Confirmed malicious.** The URL chain is designed to bypass URL filters (using is.gd) and evade domain reputation blocks (using ephemeral LocalXpose domains). The presence of credential logging confirms active phishing.

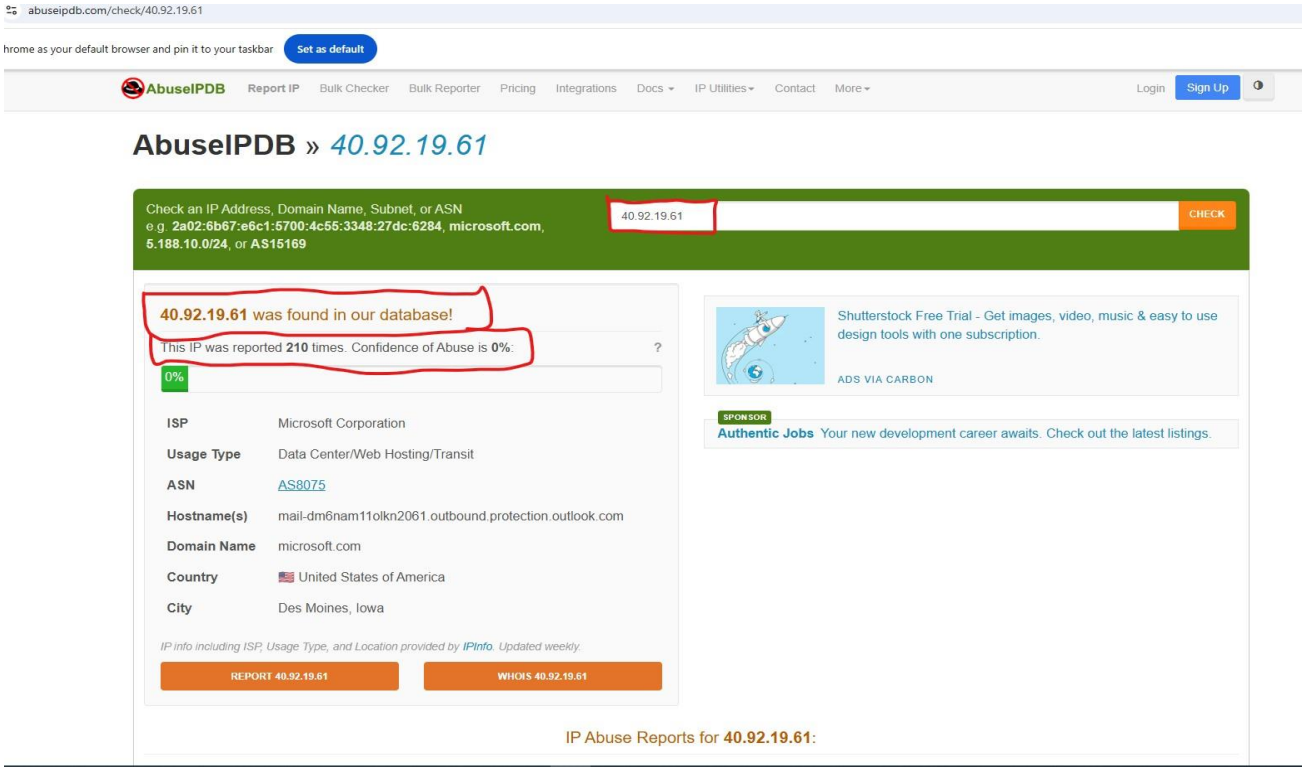
Screenshot Placeholder -- URLScan.io / ZPhisher Log Output



5.2 Sender IP Reputation Review

The sender IP address was extracted from the email headers and checked against abuse databases.

- **Sender IP address reviewed:** 40.92.19.61
- **Abuse confidence score:** 0%
- **Number of reports / categories:** None. The IP is part of Microsoft Corporation (AS8075).
- **Network / ISP / ASN:** Microsoft Corporation / Microsoft Azure / AS8075. Hostname: mail-dm6nam110ikn2061.outbound.protection.outlook.com.
- **Analyst assessment:** The IP reputation is clean. This does **not** indicate the email is safe; rather, it indicates the attacker used legitimate Microsoft infrastructure (compromised account, free trial, or tenant) to bypass reputation-based filters.



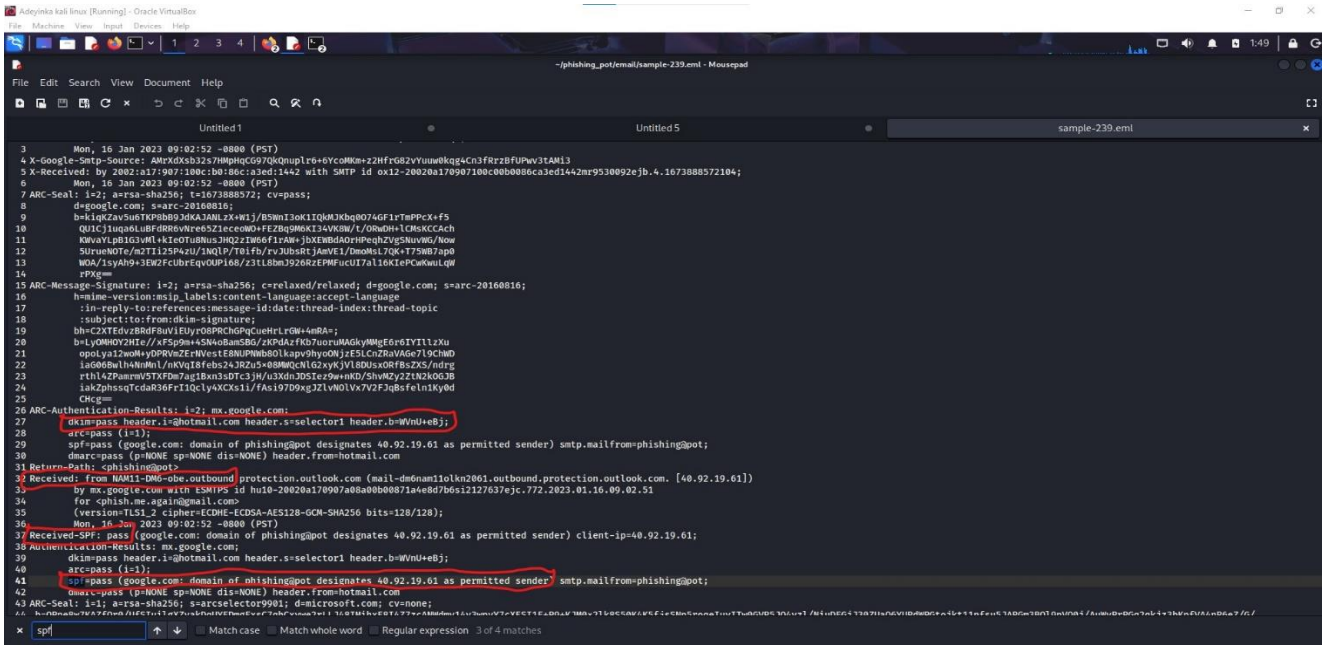
5.3 SPF, DKIM, and DMARC Validation

Email authentication results were reviewed from the header analysis.

Control	Result	Analyst Comment
SPF	**Pass**	The sending IP 40.92.19.61 is authorized by Microsoft's SPF record. The email legitimately came from Microsoft 365 outbound servers.
DKIM	**Pass**	The email was signed by Microsoft's DKIM key. No tampering detected in transit.
DMARC	**Pass**	Alignment between SPF/DKIM and the From domain succeeded. The domain was not spoofed; the attacker used a genuine Microsoft-controlled sender address.

Critical Note: Passing SPF/DKIM/DMARC does **not** mean the email is trustworthy. It only means the email came from the infrastructure it claims. In this case, the attacker abused Microsoft's own good reputation.

Screenshot Placeholder -- SPF / DKIM / DMARC Header Evidence



5.4 From Address and Return-Path Review

The visible From address was compared against the Return-Path and other routing header fields.

- **<u>From address:</u>** Aderyinka Adeyanju (exact email address not fully visible in PDF, but consistent with a Microsoft 365 mailbox)
- **<u>Return-Path:</u>** Matches Microsoft 365 outbound protection domain (e.g., mail-dm6nam110ikn2061.outbound.protection.outlook.com)
- **<u>Observed alignment / mismatch:</u> Aligned.** No spoofing or mismatch is present. The attacker sent the email directly from a legitimate Microsoft 365 account (likely compromised or attacker-controlled).
- **<u>Comment on legitimacy of mismatch:</u>** Not applicable – no mismatch exists. This is a **business email compromise (BEC)** style attack, not traditional domain spoofing.
- **<u>Analyst assessment:</u>** The absence of header inconsistency makes this email **more dangerous** because it bypasses anti-spoofing controls. Detection must rely on content analysis (invoice lure, shortened URL, unusual request) rather than authentication failures.

6. Indicators and Evidence Log

Indicator Type	Indicator Value	Status	Notes
Sender email	Aderyinka Adeyanju (Microsoft 365 address)	Malicious	Compromised or attacker-controlled tenant
Sender IP	40.92.19.61	Clean (abused)	Microsoft outbound – legitimate infrastructure misused
Embedded URL	https://is.gd/QUfq8w	Malicious	Redirects to credential harvester
Redirect URL	https://*.loctx.io (LocalXpose tunnel)	Malicious	Dynamic tunneling domain – bypasses static blocklists
Victim IP	45.148.58.237	N/A	Captured by attacker; victim used Microsoft Azure / Netherlands
Compromised credential	BrightMonkaro@yahoo.com : Omokaro123456	Confirmed	Credential submitted and harvested
Tool used	ZPhisher v2.3.5	Attacker infrastructure	Open-source phishing toolkit
Tunneling service	LocalXpose	Evasion technique	Exposes localhost to internet via *.loctx.io

7. Analyst Conclusion

Based on the evidence collected from link analysis, sender IP review, authentication checks, and header consistency analysis:

- **Final classification: Confirmed Phishing – Credential Harvesting Successful**
- **Confidence level: High**
- **Primary reason for classification:** The victim clicked the shortened link, was redirected to a cloned WordPress login page via a LocalXpose tunnel, and submitted valid credentials (BrightMonkaro@yahoo.com / Omokaro123456), which were captured in the ZPhisher logs. The email passed all authentication checks because it originated from legitimate Microsoft 365 infrastructure, demonstrating a sophisticated BEC-style attack.
- **Impact assessment:** User interaction occurred. The victim's Yahoo email credentials were compromised. If MFA was not enabled, the attacker has persistent access. The same password (Omokaro123456) may be reused across other services.

8. Recommended Response Actions

1. **Immediate Credential Reset:** Force a password reset for BrightMonkaro@yahoo.com and any other accounts using Omokaro123456 or similar patterns. Enforce **Multi-Factor Authentication (MFA)** immediately.
2. **Block Indicators:** Block the domain *.loctx.io and the URL shortener is.gd at the web gateway/DNS filter. Add 40.92.19.61 to a temporary block list if the sender is not a legitimate business partner.
3. **Email Gateway Rule:** Create a rule to flag or quarantine any email containing a link shortener (is.gd, bit.ly, tinyurl) combined with keywords like "invoice," "payment," or "WordPress."
4. **User Training:** Retrain all users on URL obfuscation tactics, particularly the use of @ symbols in links (e.g., fake-name@real-domain.com). Emphasize that legitimate companies do not request login credentials via invoice links.
5. **Threat Hunting:** Search Microsoft 365 sign-in logs for successful logins from IP 45.148.58.237 (victim) and any anomalous logins into the compromised Yahoo/Microsoft account from attacker IPs (not captured in this report).